CYBER SECURITY

vulnerabilidades em aplicações web - Linux



3 - ATAQUE À CADEIA DE SUPRIMENTOS ATINGE REPOSITÓRIO COMUNITÁRIO DO ARCH LINUX

O PROBLEMA

Ataque: Sequestro de pacotes órfãos no AUR.

Tática: Falsa atualização com injeção de código.

GLOSSÁRIO

- AUR: Arch User Repository (Repositório de Usuários do Arch).
- Arch Linux: Sistema operacional Linux (Filosofia DIY / Controle absoluto de hardware).
- PKGBUILD: Package Build (Script de texto em Bash com instruções de instalação).

ANÁLISE DE CÓDIGO E EXECUÇÃO

A Armadilha: Inspecionando o PKGBUILD

Open | PKGBUILD ~ | Save

```
1  pkgname="hello-world"
2  pkgver="1.0.0"
3  pkgrel="1"
4  pkgdesc="Hello world in your terminal!"
5  arch=("x86_64")
6  source=("hello-world.sh")
7  sha512sums=("SKIP")
8
9  package() {
10   echo 'Hello to you!' > "${srcdir}/hello-world.sh"
11   mkdir -p "${pkgdir}/usr/bin"
12   cp "${srcdir}/hello-world.sh" "${pkgdir}/usr/bin/hello-world"
13   chmod +x "${pkgdir}/usr/bin/hello-world"
14 }
15
```

sh | Tab Width: 8 | Ln 15, Col 1 | INS

Legenda:

- Linhas 1 e 2 (pkgname / pkgver): Variáveis de fachada.
- Linha 6 (source): Vetor de ataque.
- Linhas 9 a 14 (package): Execução maliciosa.

O Gatilho: A Compilação Cega no Terminal

```
hwittenborn@itsfoss:~$ ls
hello-world.sh  PKGBUILD
hwittenborn@itsfoss:~$ makepkg
==> Making package: hello-world 1.0.0-1 (Sat 08 May 2021 11:36:42 PM CDT)
==> Checking runtime dependencies...
==> Checking buildtime dependencies...
==> Retrieving sources...
  -> Found hello-world.sh
==> Validating source files with sha256sums...
    hello-world.sh ... Skipped
==> Extracting sources...
==> Starting prepare()...
==> Entering fakeroot environment...
==> Starting package()...
==> Tidying install...
  -> Removing libtool files...
  -> Purging unwanted files...
  -> Removing static library files...
  -> Stripping unneeded symbols from binaries and libraries...
  -> Compressing man and info pages...
==> Checking for packaging issues...
==> Creating package "hello-world"...
  -> Generating .PKGINFO file...
  -> Generating .BUILDINFO file...
  -> Generating .MTREE file...
  -> Compressing package...
==> Leaving fakeroot environment.
==> Finished making: hello-world 1.0.0-1 (Sat 08 May 2021 11:36:43 PM CDT)
hwittenborn@itsfoss:~$ ls
hello-world-1.0.0-1-x86_64.pkg.tar.zst  hello-world.sh  pkg  PKGBUILD  src
hwittenborn@itsfoss:~$
```

SOLUÇÕES E CONSEQUÊNCIAS

CONSEQUÊNCIAS

- Roubo de credenciais e chaves de segurança.
- Cryptojacking (sequestro de hardware para minerar cripto).
- Acesso Root (controle total do sistema).
- Lockdown do sistema (AUR bloqueado para conter danos).

SOLUÇÃO - USUÁRIO

- Regra de Ouro: Leitura obrigatória do arquivo PKGBUILD antes de qualquer instalação.
- Verificação de Fontes: Checar a procedência dos links de download (variável source).
- Análise de Comandos: Revisar as instruções de execução (função package) contra códigos suspeitos.
- Fim da Compilação Cega: Nunca executar o comando makepkg no automático sem a revisão prévia.

SOLUÇÃO - SISTEMA

- Do lado do Sistema (Arch): Política de Congelamento Permanente.
- Regra de Abandono: Congelamento imediato.
- Regra de Inatividade: Congela após 18-24 meses.
- Cronômetro de Depreciação: Aviso de contagem regressiva para congelamento.
- Continuidade: Obrigatoriedade de Fork (novo nome).